

CIS Controls Gap Analysis

Group 1

Stephanie Greene

Kayla Hodge

Mark VanDike

Jarred Ward

Issues That Need to Be Addressed at Luigi's

1. Unauthorized Personal Device Access

Luigi's allowed an employee to bring a personal laptop into the facility and connect it to the corporate wireless network. The device was not owned, configured, monitored, or managed by Luigi's.

2. Missing or Unenforced BYOD Requirements

Luigi's did not appear to have an effectively enforced bring-your-own-device policy. Personal devices should have required approval, registration, security verification, and restricted network access before connecting.

3. Missing Acceptable Use Policy

Luigi's did not have or enforce an acceptable use policy defining whether personal devices could connect to the corporate network, what activities were prohibited, and what security requirements users had to follow. A clear policy should have prohibited unapproved devices and required authorization before any personal system accessed company resources.

4. Lack of Device Security Verification and Endpoint Protection

The personal laptop did not have Luigi's approved endpoint protection, and the network did not verify its antivirus, antimalware, patch, or configuration status before allowing access. Any device without current security protection should have been denied access or placed in an isolated remediation network until it passed a device-health inspection.

5. Inadequate Asset Inventory and Discovery

Luigi's did not immediately identify the laptop as an unauthorized asset after it connected. DHCP records, network-discovery tools, and the enterprise asset inventory should have been used to recognize and quarantine the unknown device.

6. Weak Wireless Authentication and Authorization

The wireless access point allowed an unmanaged personal laptop to connect without strong enterprise authentication. Luigi's did not verify an approved user or device identity before granting corporate network access.

7. Insufficient Network Segmentation

The personal laptop was placed on a network that allowed it to reach internal corporate systems. Personal and guest devices should have been isolated from employee systems, servers, and sensitive-data environments.

8. Excessively Permissive DHCP and Network Access

The core DHCP service automatically issued the personal laptop a corporate IP address. Receiving an IP address effectively provided the device with more internal access than an unknown and unmanaged system should have received.

9. Successful Malware Command-and-Control Communication

The PSL malware was able to connect to an external command-and-control server. Luigi's outbound security controls did not prevent the attacker from remotely controlling the compromised laptop.

10. Outdated Malicious-Destination Information

The NOC used a list of known malicious destinations that was four months out of date. This reduced the likelihood that newly identified or recently created malicious infrastructure would be blocked or recognized.

11. Insufficient Detection of Internal Scanning

The threat actor commanded the laptop to scan Luigi's internal network for available services. The scanning activity was not prevented, immediately detected, or escalated as a security incident.

12. Exposed FTP Service

An internal FTP service was accessible from the employee wireless network. Sensitive servers and services should not have been directly reachable from unmanaged or lower-trust devices.

13. Anonymous FTP Access

The FTP server permitted anonymous access without requiring an approved username, password, device, or business purpose. The attacker was therefore able to log in without compromising a legitimate employee account.

14. Unnecessary or Insecure Network Service

The FTP service may not have been necessary for current business operations. If it was necessary, Luigi's should have replaced it with a secure, authenticated, and properly restricted file-transfer method.

15. Improper Default-Allow Firewall Rules

Luigi's firewall rules were too permissive because connections were generally allowed unless a destination or activity appeared on a known-bad list. The organization should have followed a default-deny approach in which inbound and outbound connections were blocked unless they were explicitly

authorized for a documented business purpose. Server firewall rules should also have restricted FTP access to approved systems, users, and network segments.

16. Inadequate Data Inventory and Classification

Luigi's stored patents, proprietary drawings, price quotes, parts lists, and legal documents without sufficient evidence that the information had been inventoried and classified. These records should have been identified as confidential or restricted.

17. Excessive Access to Sensitive Information

Sensitive files were stored in directories that could be accessed anonymously. Access should have been restricted to approved users with a legitimate need to know.

18. Lack of Encryption for Stored Sensitive Data

The case provides no evidence that the patents, proprietary drawings, legal documents, price quotes, or parts lists were encrypted at rest. Encryption would not replace proper access controls, but it could reduce exposure if an attacker accessed the server, removed its storage media, or copied protected files.

19. Lack of Sensitivity-Based Data Segmentation

High-value proprietary and legal records were stored on a server reachable from a general wireless network. Sensitive information should have been separated from lower-trust users, devices, and systems.

20. No Outbound Connection Allow List

Luigi's allowed the compromised laptop to establish an external command-and-control session and an unauthorized encrypted VPN connection. Outbound traffic should have been limited to approved destinations, ports, protocols, applications, and business services. Connections that were not explicitly permitted should have been blocked or immediately escalated for investigation.

21. No Inactivity Log-Out or Session-Lock Timer

The employee left the laptop powered on, logged in, and connected throughout the three-day weekend. Luigi's should have enforced an automatic session lock or logout after a defined period of inactivity to reduce the risks created by unattended devices and active authenticated sessions.

22. Unrestricted Encrypted Outbound Traffic

The attacker transferred a large amount of data through an encrypted outbound VPN connection. Luigi's did not sufficiently restrict or alert on unauthorized VPN connections from employee or personal-device network segments.

23. Inadequate Log Correlation and Security Monitoring

The NOC identified the source, destination, and volume of the encrypted traffic but did not have enough correlated information to understand the complete attack. DHCP, DNS, FTP, endpoint, firewall, and network-flow data should have been reviewed together.

24. Failure to Immediately Contain Suspicious Activity

The NOC observed a large, encrypted data transfer but did not immediately isolate the source device, block the destination, or restrict the FTP server. Instead, the event was handled through a routine desktop-support ticket.

25. Delayed Employee Reporting

The employee noticed that the laptop was slow and behaving abnormally but did not report the problem before leaving. The device remained powered on and connected throughout the three-day weekend.

26. Weak After-Hours Incident Escalation

Luigi's lacked an effective process for escalating suspicious weekend activity to security personnel and decision-makers. The response was delayed until the employee and desktop technician returned on Tuesday.

27. Incomplete Incident-Response Procedures

The case does not show a coordinated response involving immediate containment, evidence preservation, data-owner notification, legal review, eradication, and recovery. The response primarily focused on locating and confiscating the laptop.

28. Premature Ticket Closure and Insufficient Post-Incident Review

The ticket was closed after the laptop was confiscated even though the broader incident still required investigation. Luigi's needed to determine which files were stolen, whether other systems were compromised, and which corrective actions were necessary.

CIS Controls That Could Have Helped Prevent the Attack

1. CIS Control 1: Inventory and Control of Enterprise Assets
2. CIS Control 2: Inventory and Control of Software Assets
3. CIS Control 3: Data Protection
4. CIS Control 4: Secure Configuration of Enterprise Assets and Software
5. CIS Control 5: Account Management
6. CIS Control 6: Access Control Management
7. CIS Control 7: Continuous Vulnerability Management
8. CIS Control 8: Audit Log Management
9. CIS Control 9: Email and Web Browser Protections
10. CIS Control 10: Malware Defenses
11. CIS Control 11: Data Recovery
12. CIS Control 12: Network Infrastructure Management
13. CIS Control 13: Network Monitoring and Defense
14. CIS Control 14: Security Awareness and Skills Training
15. CIS Control 15: Service Provider Management
16. CIS Control 17: Incident Response Management

CIS Control 1: Inventory and Control of Enterprise Assets

CIS Control 1 is important because Luigi's allowed an unknown personal laptop to receive an internal IP address and access corporate resources. An accurate asset inventory would have identified the laptop as personally owned, unmanaged, and unauthorized. Asset-discovery and quarantine procedures could have removed or isolated the device shortly after it connected. This Control would have prevented the attacker from freely using an unknown endpoint as an internal attack platform.

CIS Control 2: Inventory and Control of Software Assets

CIS Control 2 is important because Luigi's lacked sufficient visibility and control over software operating on devices connected to its network. A maintained software inventory and process for addressing unauthorized or unsupported applications could identify malicious programs, unapproved remote-access tools, and insecure software. Although this Control might not independently have stopped the attack, it is an IG1 baseline that reduces software-related risk.

CIS Control 3: Data Protection

CIS Control 3 is important because the FTP server contained patents, proprietary drawings, legal records, price quotes, and parts lists. These files should have been inventoried, classified, and protected according to their sensitivity and business value. Access controls and sensitivity-based segmentation

would have limited the amount of information available through the FTP server. This Control would have reduced both the probability and potential impact of the data theft.

CIS Control 4: Secure Configuration of Enterprise Assets and Software

CIS Control 4 is important because insecure configurations gave the attacker an easy method of accessing sensitive information. Anonymous FTP access, an exposed network service, and permissive server firewall rules created a direct path to the files. Secure configuration standards would have required Luigi's to disable anonymous access, remove unnecessary services, and restrict server connections. This Control would have eliminated or significantly reduced the FTP server's exposure.

CIS Control 5: Account Management

CIS Control 5 is important because Luigi's needed clear ownership and management of user, administrative, service, and anonymous accounts. An account inventory, unique credentials, dormant-account removal, and dedicated administrative accounts would improve accountability and reduce unauthorized access. These requirements would also make anonymous FTP access inconsistent with Luigi's approved account-management practices.

CIS Control 6: Access Control Management

CIS Control 6 is important because the FTP server allowed access without verifying the requester's identity, device, role, or business need. Anonymous access prevented Luigi's from enforcing accountability or determining whether a user was authorized to view the files. A documented access-granting process and centralized authentication would have required approved enterprise credentials. This Control would have prevented the attacker from accessing sensitive directories without a legitimate account.

CIS Control 7: Continuous Vulnerability Management

CIS Control 7 is important because vulnerability scanning could have identified the accessible FTP service and anonymous login configuration before the attacker discovered them. Luigi's needed a formal process for identifying, prioritizing, assigning, and correcting weaknesses in internal systems. Authenticated and unauthenticated scans would have shown what ordinary network devices and administrators could access. This Control would have allowed Luigi's to remediate the exposure before it was exploited.

CIS Control 8: Audit Log Management

CIS Control 8 is important because Luigi's possessed some network information but lacked enough correlated evidence to understand the incident quickly. Logs from DHCP, DNS, the FTP server, firewalls, network devices, and security tools could have shown the complete attack sequence.

Centralized collection and review would have connected the new device, internal scanning, FTP activity, and outbound transfer. This Control would have improved detection, investigation, attribution, and incident-response decisions.

CIS Control 9: Email and Web Browser Protections

CIS Control 9 is important because it includes DNS and network-based URL filtering that could have interrupted the malware's command-and-control connection. Luigi's relied on a malicious-destination list that had not been updated for four months. Current domain and URL filtering would have provided broader protection than a manually maintained list. This Control could have blocked the external connection before the attacker instructed the laptop to scan Luigi's network.

CIS Control 10: Malware Defenses

CIS Control 10 is important because PSL malware provided the attacker with remote control of the personal laptop. Managed and automatically updated anti-malware software could have identified the known PSL signature before or shortly after the device connected. Behavior-based protection could also have detected command-and-control activity, network scanning, or unusual file compression. This Control would have directly addressed the malicious software responsible for initiating the attack.

CIS Control 11: Data Recovery

CIS Control 11 is important because Luigi's needed reliable backups and protected recovery data following a major security incident. Data recovery controls would not have prevented the initial theft, but they would support restoration if systems or information were altered, deleted, corrupted, or encrypted. As an IG1 Control, it should be part of Luigi's minimum cybersecurity foundation.

CIS Control 12: Network Infrastructure Management

CIS Control 12 is important because Luigi's network treated an unmanaged personal laptop as though it were a trusted corporate device. The laptop received an internal address and was able to communicate with systems containing sensitive information. Secure network architecture and centralized network authentication would have separated unknown devices from trusted users and servers. This Control would have reduced the laptop's ability to move from wireless access to sensitive internal resources.

CIS Control 13: Network Monitoring and Defense

CIS Control 13 is important because Luigi's detected unusual traffic but failed to interpret and contain it effectively. Network intrusion detection, centralized security alerts, traffic filtering, and flow monitoring could have identified internal scanning and the large outbound transfer. These technologies

can provide useful evidence even when the contents of a connection are encrypted. This Control would have helped Luigi's recognize the activity as a security incident and isolate the device sooner.

CIS Control 14: Security Awareness and Skills Training

CIS Control 14 is important because employee behavior and responder decisions increased the length and severity of the incident. The employee noticed abnormal performance but left the laptop powered on and connected throughout the holiday weekend. The NOC and help desk also failed to immediately treat the suspicious encrypted transfer as a serious security event. This Control would have improved employee reporting and the technical decision-making of personnel with security responsibilities.

CIS Control 15: Service Provider Management

CIS Control 15 is important because Luigi's may rely on external providers for networking, cloud services, software, security tools, or technical support. Maintaining an inventory of service providers helps the company identify dependencies, assign internal owners, and understand third-party access. Although it may not have prevented this incident, it is an IG1 requirement that strengthens overall security oversight.

CIS Control 17: Incident Response Management

CIS Control 17 is important because Luigi's observed suspicious activity but did not respond with sufficient urgency or coordination. The NOC created a routine desktop-services ticket instead of isolating the source device, blocking the destination, and protecting the FTP server. A documented incident-response process would have established authority, escalation paths, communication methods, and after-hours responsibilities. This Control would have reduced the time the attacker remained active and improved the organization's investigation and recovery.

Safeguards That Should Have Been Implemented

1. CIS Control 1: Inventory and Control of Enterprise Assets

- Safeguard 1.1: Establish and Maintain Detailed Enterprise Asset Inventory
- Safeguard 1.2: Address Unauthorized Assets
- Safeguard 1.3: Utilize an Active Discovery Tool
- Safeguard 1.4: Use Dynamic Host Configuration Protocol Logging to Update Enterprise Asset Inventory

2. CIS Control 2: Inventory and Control of Software Assets

- Safeguard 2.1: Establish and Maintain a Software Inventory
- Safeguard 2.2: Ensure Authorized Software is Currently Supported
- Safeguard 2.3: Address Unauthorized Software

3. CIS Control 3: Data Protection

- Safeguard 3.1: Establish and Maintain a Data Management Process
- Safeguard 3.2: Establish and Maintain a Data Inventory
- Safeguard 3.3: Configure Data Access Control Lists
- Safeguard 3.4: Enforce Data Retention
- Safeguard 3.5: Securely Dispose of Data
- Safeguard 3.6: Encrypt Data on End-User Devices
- Safeguard 3.7: Establish and Maintain a Data Classification Scheme
- Safeguard 3.12: Segment Data Processing and Storage Based on Sensitivity

4. CIS Control 4: Secure Configuration of Enterprise Assets and Software

- Safeguard 4.1: Establish and Maintain a Secure Configuration Process
- Safeguard 4.2: Establish and Maintain a Secure Configuration Process for Network Infrastructure
- Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets
- Safeguard 4.4: Implement and Manage a Firewall on Servers
- Safeguard 4.5: Implement and Manage a Firewall on End-User Devices
- Safeguard 4.6: Securely Manage Enterprise Assets and Software
- Safeguard 4.7: Manage Default Accounts on Enterprise Assets and Software
- Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software

5. CIS Control 5: Account Management

- Safeguard 5.1: Establish and Maintain an Inventory of Accounts
- Safeguard 5.2: Use Unique Passwords
- Safeguard 5.3: Disable Dormant Accounts
- Safeguard 5.4: Restrict Administrator Privileges to Dedicated Administrator Accounts

6. CIS Control 6: Access Control Management

- Safeguard 6.1: Establish an Access Granting Process
- Safeguard 6.2: Establish an Access Revoking Process
- Safeguard 6.3: Require MFA for Externally-Exposed Applications
- Safeguard 6.4: Require MFA for Remote Network Access
- Safeguard 6.5: Require MFA for Administrative Access
- Safeguard 6.7: Centralize Access Control

7. CIS Control 7: Continuous Vulnerability Management

- Safeguard 7.1: Establish and Maintain a Vulnerability Management Process
- Safeguard 7.2: Establish and Maintain a Remediation Process
- Safeguard 7.3: Perform Automated Operating System Patch Management
- Safeguard 7.4: Perform Automated Application Patch Management
- Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets
- Safeguard 7.7: Remediate Detected Vulnerabilities

8. CIS Control 8: Audit Log Management

- Safeguard 8.1: Establish and Maintain an Audit Log Management Process
- Safeguard 8.2: Collect Audit Logs
- Safeguard 8.3: Ensure Adequate Audit Log Storage
- Safeguard 8.6: Collect DNS Query Audit Logs
- Safeguard 8.7: Collect URL Request Audit Logs
- Safeguard 8.9: Centralize Audit Logs
- Safeguard 8.11: Conduct Audit Log Reviews

9. CIS Control 9: Email and Web Browser Protections

- Safeguard 9.1: Ensure Use of Only Fully Supported Browsers and Email Clients
- Safeguard 9.2: Use DNS Filtering Services
- Safeguard 9.3: Maintain and Enforce Network-Based URL Filters

10. CIS Control 10: Malware Defenses

- Safeguard 10.1: Deploy and Maintain Anti-Malware Software
- Safeguard 10.2: Configure Automatic Anti-Malware Signature Updates
- Safeguard 10.3: Disable Autorun and Autoplay for Removable Media
- Safeguard 10.6: Centrally Manage Anti-Malware Software
- Safeguard 10.7: Use Behavior-Based Anti-Malware Software

11. CIS Control 11: Data Recovery

- Safeguard 11.1: Establish and Maintain a Data Recovery Process
- Safeguard 11.2: Perform Automated Backups
- Safeguard 11.3: Protect Recovery Data
- Safeguard 11.4: Establish and Maintain an Isolated Instance of Recovery Data

12. CIS Control 12: Network Infrastructure Management

- Safeguard 12.1: Ensure Network Infrastructure is Up-to-Date
- Safeguard 12.2: Establish and Maintain a Secure Network Architecture
- Safeguard 12.5: Centralize Network Authentication, Authorization, and Auditing
- Safeguard 12.6: Use Secure Network Management and Communication Protocols

13. CIS Control 13: Network Monitoring and Defense

- Safeguard 13.1: Centralize Security Event Alerting
- Safeguard 13.3: Deploy a Network Intrusion Detection Solution
- Safeguard 13.4: Perform Traffic Filtering Between Network Segments
- Safeguard 13.6: Collect Network Traffic Flow Logs

14. CIS Control 14: Security Awareness and Skills Training

- Safeguard 14.1: Establish and Maintain a Security Awareness Program
- Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks
- Safeguard 14.3: Train Workforce Members on Authentication Best Practices
- Safeguard 14.4: Train Workforce on Data Handling Best Practices
- Safeguard 14.5: Train Workforce Members on Causes of Unintentional Data Exposure
- Safeguard 14.6: Train Workforce Members on Recognizing and Reporting Security Incidents
- Safeguard 14.7: Train Workforce on How to Identify and Report if Their Enterprise Assets are Missing Security Updates
- Safeguard 14.8: Train Workforce on the Dangers of Connecting to and Transmitting Enterprise Data Over Insecure Networks
- Safeguard 14.9: Conduct Role-Specific Security Awareness and Skills Training

15. CIS Control 15: Service Provider Management

- Safeguard 15.1: Establish and Maintain an Inventory of Service Providers

16. CIS Control 17: Incident Response Management

- Safeguard 17.1: Designate Personnel to Manage Incident Handling
- Safeguard 17.2: Establish and Maintain Contact Information for Reporting Security Incidents
- Safeguard 17.3: Establish and Maintain an Enterprise Process for Reporting Incidents
- Safeguard 17.4: Establish and Maintain an Incident Response Process
- Safeguard 17.5: Assign Key Roles and Responsibilities
- Safeguard 17.6: Define Mechanisms for Communicating During Incident Response
- Safeguard 17.7: Conduct Routine Incident Response Exercises
- Safeguard 17.8: Conduct Post-Incident Reviews

CIS Control 1: Inventory and Control of Enterprise Assets

- ***Safeguard 1.1: Establish and Maintain Detailed Enterprise Asset Inventory***

Luigi's should maintain a current inventory of corporate, personal, portable, network, and server assets, including each asset's owner, department, network address, hardware address, and approval status. This Safeguard is important because Luigi's did not immediately know that the laptop was a personal and unmanaged device. Support personnel could compare new network connections against the inventory and quickly recognize devices that did not belong. This visibility would have helped Luigi's isolate the laptop before it was used to attack internal systems.

- ***Safeguard 1.2: Address Unauthorized Assets***

Luigi's should establish a process to remove, deny, or quarantine devices that are not authorized to use the corporate network. This Safeguard is important because merely identifying an unauthorized device does not eliminate the risk it creates. Quarantine could provide limited access for registration or security inspection without exposing internal servers and sensitive information. Applying this process to the employee's laptop would have interrupted the attack before the internal network scan occurred.

- ***Safeguard 1.3: Utilize an Active Discovery Tool***

Luigi's should use an active discovery tool to identify devices connected to the network on a daily or more frequent basis. This Safeguard is important because the tool could have detected the personal laptop shortly after it joined the network. An alert for a new or unknown device could then be compared with Luigi's approved asset inventory. This process would have significantly shortened the amount of time the infected laptop remained connected and unidentified.

- ***Safeguard 1.4: Use Dynamic Host Configuration Protocol Logging to Update Enterprise Asset Inventory***

Luigi's should use DHCP or IP-address-management records to associate assigned addresses with known devices and update its asset inventory. This Safeguard is important because Luigi's DHCP server assigned the personal laptop an internal corporate IP address. Comparing DHCP records with the approved inventory would have shown that the laptop was not a recognized corporate asset. The records would also have provided the NOC with useful device and connection information when investigating the suspicious weekend traffic.

CIS Control 2: Inventory and Control of Software Assets

- ***Safeguard 2.1: Establish and Maintain a Software Inventory***

Luigi's should maintain a current inventory of all authorized software installed on enterprise assets, including the publisher, version, business purpose, support status, and responsible owner. This Safeguard is important because the company lacked visibility into software operating on connected devices. A complete inventory would help identify unapproved applications and distinguish legitimate tools from malicious or unnecessary software.

- ***Safeguard 2.2: Ensure Authorized Software is Currently Supported***

Luigi's should ensure that software designated as authorized is currently supported and receiving security updates from its vendor. Unsupported software should be upgraded, replaced, removed, or covered by a documented exception with mitigating controls. This Safeguard reduces the likelihood that known but uncorrected software weaknesses remain available to attackers.

- ***Safeguard 2.3: Address Unauthorized Software***

Luigi's should establish a recurring process to remove unauthorized software or document a formally approved exception. This Safeguard is important because unapproved applications can introduce malware, insecure services, remote-access capabilities, or unsupported components. Promptly addressing unauthorized software would reduce the number of unmonitored tools capable of operating within the corporate environment.

CIS Control 3: Data Protection

- ***Safeguard 3.1: Establish and Maintain a Data Management Process***

Luigi's should establish requirements covering data ownership, sensitivity, handling, retention, access, and secure disposal. This Safeguard is important because Luigi's lacked visible governance over the high-value information stored on the FTP server. Patents, proprietary drawings, legal records, pricing information, and parts lists would receive protection based on their sensitivity and business value. A documented data management process would make storing this information on an anonymously accessible FTP server clearly unacceptable.

- ***Safeguard 3.2: Establish and Maintain a Data Inventory***

Luigi's should identify sensitive information and document where it is stored, processed, and transmitted. This Safeguard is important because Luigi's must know what sensitive information it possesses and which systems contain it. A data inventory would have identified the FTP server as a repository containing intellectual property and legal records requiring greater protection.

- ***Safeguard 3.3: Configure Data Access Control Lists***

Luigi's should restrict file, application, and database permissions according to each user's legitimate need to know. This Safeguard is important because the FTP server allowed an anonymous user to read and copy sensitive directories. Proper access control lists would limit each file and folder to specifically authorized users or groups. An infected personal laptop would not receive access merely because it was connected to Luigi's internal network.

- ***Safeguard 3.4: Enforce Data Retention***

Luigi's should define and enforce minimum and maximum retention periods for patents, drawings, legal records, pricing information, parts lists, and other sensitive data. Keeping information longer than necessary increases the volume of material exposed during a breach. Enforced retention requirements would limit unnecessary data accumulation and support consistent handling throughout the information lifecycle.

- ***Safeguard 3.5: Securely Dispose of Data***

Luigi's should securely dispose of sensitive information when its approved retention period ends or when it is no longer required. Disposal methods should match the sensitivity of the data and include verified deletion or physical media destruction. This Safeguard would prevent attackers or unauthorized personnel from recovering information that the company no longer needed to retain.

- ***Safeguard 3.6: Encrypt Data on End-User Devices***

Luigi's should require encryption on end-user devices that store sensitive company information, including authorized laptops and approved personal devices. Full-disk or equivalent encryption would reduce exposure if a device were lost, stolen, accessed without permission, or used to hold copied proprietary files. Devices that cannot meet this requirement should be denied sensitive-data access.

- ***Safeguard 3.7: Establish and Maintain a Data Classification Scheme***

Luigi's should classify information using categories such as public, internal, confidential, and restricted. This Safeguard is important because the company's information did not appear to be protected according to its sensitivity. Patents, proprietary drawings, pricing records, and legal documents should have been classified as confidential or restricted. Those classifications would require stronger storage, access, monitoring, transmission, and approval controls than ordinary internal information.

- ***Safeguard 3.12: Segment Data Processing and Storage Based on Sensitivity***

Luigi's should separate sensitive information and supporting systems from lower-trust users, devices, and network segments. This Safeguard is important because the personal wireless laptop could directly reach the server containing sensitive information. Firewall and routing policies should allow connections to restricted data only from approved systems with a documented business requirement. This segmentation would have prevented or significantly limited the attacker's access to the FTP server.

CIS Control 4: Secure Configuration of Enterprise Assets and Software

- ***Safeguard 4.1: Establish and Maintain a Secure Configuration Process***

Luigi's should document approved security configurations for servers, operating systems, applications, and end-user devices. This Safeguard is important because the organization lacked an effective baseline preventing insecure server and endpoint configurations. The standard could prohibit anonymous services, require security software, restrict unnecessary ports, and define logging requirements. Comparing systems with the approved baseline would have exposed several of the weaknesses involved in the attack.

- ***Safeguard 4.2: Establish and Maintain a Secure Configuration Process for Network Infrastructure***

Luigi's should establish approved configurations for access points, routers, switches, DHCP services, firewalls, and other network infrastructure. This Safeguard is important because the

network allowed an unmanaged laptop to obtain an address and reach internal services. The standard should establish secure wireless settings and rules separating guest or personal devices from trusted corporate systems. Applying these requirements would have reduced the infected laptop's ability to access Luigi's internal network.

- ***Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets***

Luigi's should configure automatic session locking after a defined period of inactivity, not exceeding the CIS requirement for general-purpose operating systems. This Safeguard directly addresses the laptop remaining active throughout the three-day weekend. Automatic locking would reduce the risk that an unattended, authenticated session could be used to access company systems or continue malicious activity.

- ***Safeguard 4.4: Implement and Manage a Firewall on Servers***

Luigi's should use host-based or virtual firewalls to limit server connections to approved sources, ports, applications, and network segments. This Safeguard is important because the FTP server accepted a connection from an untrusted device on the wireless network. The FTP service could remain unreachable to ordinary employee and personal devices even if its port were active. Proper server firewall restrictions would have blocked the compromised laptop from reaching the sensitive repository.

- ***Safeguard 4.5: Implement and Manage a Firewall on End-User Devices***

Luigi's should implement and centrally manage host-based firewalls on every end-user device authorized to access corporate resources. The firewall should use a default-deny rule and permit only explicitly approved ports, services, and connections. This Safeguard would reduce unnecessary inbound and outbound communication from compromised devices, including unauthorized command-and-control or VPN traffic.

- ***Safeguard 4.6: Securely Manage Enterprise Assets and Software***

Luigi's should manage enterprise assets and software through approved administrative tools, protected interfaces, and secure protocols such as SSH and HTTPS. Insecure management protocols should be prohibited unless a documented operational exception exists. This Safeguard would reduce exposure of credentials and configurations while ensuring that administrators make controlled and auditable security changes.

- ***Safeguard 4.7: Manage Default Accounts on Enterprise Assets and Software***

Luigi's should disable, rename, or otherwise restrict default accounts on servers, applications, and network devices. Default, anonymous, and preconfigured accounts weaken accountability and create predictable access paths for attackers. Proper management would have made the FTP server's anonymous access inconsistent with the company's approved security baseline and easier to detect.

- ***Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software***

Luigi's should disable FTP if it does not support a current and documented business need. This Safeguard is important because the attack depended on an accessible FTP service that permitted anonymous access. When file transfer is necessary, the company should replace FTP with a secure alternative requiring authentication and encrypted communication. Removing or replacing the service would eliminate the specific access path used to steal the information.

CIS Control 5: Account Management

- ***Safeguard 5.1: Establish and Maintain an Inventory of Accounts***

Luigi's should maintain an inventory of user, administrator, service, application, and other enterprise accounts, including each account's owner, purpose, authorization, and status. This inventory would make anonymous, unnecessary, dormant, or unowned accounts easier to identify. Regular validation would also confirm that every active account remains approved for a legitimate business need.

- ***Safeguard 5.2: Use Unique Passwords***

Luigi's should require unique passwords for all enterprise accounts and prohibit shared or reused credentials. Unique authentication improves accountability, limits the effect of a compromised password, and prevents multiple users or services from relying on credentials that cannot be traced to one person. Password requirements should align with whether multifactor authentication is enforced.

- ***Safeguard 5.3: Disable Dormant Accounts***

Luigi's should disable or delete dormant accounts after the defined period of inactivity and review inactive accounts regularly. Unused accounts create unnecessary access paths that attackers may exploit without attracting immediate attention. Removing these accounts would reduce risk from former employees, abandoned services, and outdated applications that no longer require access.

- ***Safeguard 5.4: Restrict Administrator Privileges to Dedicated Administrator Accounts***

Luigi's should require administrators to use dedicated privileged accounts only for administrative activities and separate standard accounts for routine work. This Safeguard limits exposure of elevated credentials during web browsing, email, and everyday productivity tasks. It also reduces the damage malware can cause when it compromises an employee's normal user session.

CIS Control 6: Access Control Management

- ***Safeguard 6.1: Establish an Access Granting Process***

Luigi's should require documented authorization before granting access to enterprise systems or sensitive information. This Safeguard is important because no formal authorization occurred before the attacker accessed the FTP server. The process should record the user's identity, role, requested permissions, business need, and approval from the appropriate manager or data owner. Anonymous access would not satisfy these requirements and therefore would not be permitted.

- ***Safeguard 6.2: Establish an Access Revoking Process***

Luigi's should establish a documented and preferably automated process for revoking access when employment, roles, devices, or business requirements change. Access should be disabled immediately when authorization ends while preserving necessary audit records. This Safeguard would reduce excessive permissions and prevent users or systems from retaining access to sensitive information without a current need.

- ***Safeguard 6.3: Require MFA for Externally-Exposed Applications***

Luigi's should require multifactor authentication for all externally exposed enterprise and third-party applications where supported. Although the compromised FTP server was internally accessible, this Safeguard strengthens internet-facing systems and prevents a stolen password alone from granting access. Central enforcement through an identity provider would also improve consistency and accountability.

- ***Safeguard 6.4: Require MFA for Remote Network Access***

Luigi's should require multifactor authentication for every approved remote network connection, including enterprise VPN access. This Safeguard would help ensure that only verified users establish remote sessions and would distinguish legitimate company connections from unauthorized VPN activity. Remote access that cannot enforce MFA should be blocked or formally excepted with compensating controls.

- ***Safeguard 6.5: Require MFA for Administrative Access***

Luigi's should require multifactor authentication for all administrative access to servers, network devices, security tools, applications, and third-party management platforms. Stronger verification would reduce the likelihood that compromised credentials allow an attacker to change firewall rules, disable protections, or alter sensitive configurations. Administrative access should also be logged and reviewed.

- ***Safeguard 6.7: Centralize Access Control***

Luigi's should use an enterprise directory or single sign-on provider to control access to supported systems and applications. This Safeguard is important because a separately configured anonymous service can bypass the company's normal identity-management controls. Users could be authenticated, assigned to approved groups, disabled when necessary, and associated with audit records. Centralized access control would prevent the FTP service from granting sensitive access to an unidentified attacker.

CIS Control 7: Continuous Vulnerability Management

- ***Safeguard 7.1: Establish and Maintain a Vulnerability Management Process***

Luigi's should document how vulnerabilities and insecure configurations are identified, evaluated, prioritized, assigned, monitored, and reported. This Safeguard is important because the company needed a recurring method for identifying insecure systems before attackers discovered them. Anonymous FTP access and excessive network exposure would be documented as weaknesses requiring corrective action. A formal process would prevent these findings from being overlooked or handled inconsistently.

- ***Safeguard 7.2: Establish and Maintain a Remediation Process***

Luigi's should establish risk-based deadlines, responsible personnel, escalation procedures, and evidence requirements for correcting identified security weaknesses. This Safeguard is important because discovering a weakness does not provide protection unless it is corrected. The FTP owner would have to disable anonymous access, restrict the service, replace it, or document an approved exception. This process would increase the likelihood that the exposure was corrected before an attacker could exploit it.

- ***Safeguard 7.3: Perform Automated Operating System Patch Management***

Luigi's should automate operating-system patch deployment and verify that security updates are installed on enterprise assets at least monthly or more frequently when risk requires it. Current operating systems reduce known exploitable weaknesses on servers and endpoints. Patch compliance should also be included in the device-health checks performed before granting network access.

- ***Safeguard 7.4: Perform Automated Application Patch Management***

Luigi's should automate application patching for browsers, file-transfer software, security tools, and other supported applications on enterprise assets. Timely updates reduce known vulnerabilities that attackers can exploit after gaining network access. Patch status should be

centrally monitored, and failures should be assigned, escalated, corrected, and verified through the remediation process.

- ***Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets***

Luigi's should conduct recurring authenticated and unauthenticated vulnerability scans against its internal systems. This Safeguard is important because an internal scan could have discovered the same FTP service found by the attacker. An unauthenticated scan would show what an ordinary device could access, while an authenticated scan could evaluate the server's software and configuration in greater detail. Conducting these scans regularly would have allowed Luigi's to identify and correct the problem first.

- ***Safeguard 7.7: Remediate Detected Vulnerabilities***

Luigi's should correct detected vulnerabilities and verify that each corrective action was successful. This Safeguard is important because identified technical weaknesses must be addressed rather than simply recorded in a report. Administrators should disable anonymous FTP, remove unnecessary services, restrict server access, and update affected software when appropriate. A follow-up scan or configuration review would confirm that the exposure had actually been eliminated.

CIS Control 8: Audit Log Management

- ***Safeguard 8.1: Establish and Maintain an Audit Log Management Process***

Luigi's should define which logs must be collected, protected, retained, reviewed, and investigated. This Safeguard is important because consistent logging requirements are needed across DHCP, wireless, firewall, DNS, FTP, endpoint, server, and outbound-connection systems. The process should establish retention periods, access restrictions, review frequency, and responsibility for investigating anomalies. These requirements would provide analysts with more complete evidence when suspicious activity occurred.

- ***Safeguard 8.2: Collect Audit Logs***

Luigi's should enable logging across relevant enterprise systems, applications, servers, security tools, and network infrastructure. This Safeguard is important because the attack crossed several devices and services that should have generated useful records. The logs could show the laptop receiving an address, scanning systems, accessing FTP directories, and communicating with an external server. Collecting this information would support faster detection, accurate incident scoping, and reliable forensic conclusions.

- ***Safeguard 8.3: Ensure Adequate Audit Log Storage***

Luigi's should allocate enough protected storage to retain audit logs for the periods defined in its log-management process. Adequate capacity would prevent important DHCP, DNS, FTP, firewall, endpoint, and network-flow evidence from being overwritten before analysts recognized the incident. Storage utilization and collection failures should be monitored and addressed promptly.

- ***Safeguard 8.6: Collect DNS Query Audit Logs***

Luigi's should collect DNS query logs to identify suspicious external domains contacted by internal devices. This Safeguard is important because the infected laptop may have used DNS to locate its command-and-control server. The logs could reveal repeated queries to an unusual domain even though the later network communication was encrypted. This evidence would help detect the malware even though the destination was absent from Luigi's outdated malicious-site list.

- ***Safeguard 8.7: Collect URL Request Audit Logs***

Luigi's should record web, proxy, and URL requests where technically supported. This Safeguard is important because these records can provide additional information about external destinations contacted by enterprise devices. The logs may show unusual request paths, repeated connections, or patterns associated with automated malware activity. When combined with DHCP and DNS records, they could attribute the suspicious traffic to the employee's personal laptop.

- ***Safeguard 8.9: Centralize Audit Logs***

Luigi's should send relevant logs to a central platform where activity from different systems can be correlated. This Safeguard is important because the attack involved wireless access, DHCP, an endpoint, an FTP server, DNS, and the internet boundary. A single timeline could show that a new device connected shortly before internal scanning and a large outbound transfer. This correlation would make the seriousness of the event easier for the NOC to recognize.

- ***Safeguard 8.11: Conduct Audit Log Reviews***

Luigi's should regularly review audit logs and investigate anomalies, suspicious events, and indicators of compromise. This Safeguard is important because collected logs provide limited value when personnel do not actively review or alert on them. Reviews should identify unusual transfer volumes, unknown destinations, anonymous server access, internal scans, and newly connected devices. The weekend transfer should have triggered an immediate security investigation rather than a routine desktop-services ticket.

CIS Control 9: Email and Web Browser Protections

- ***Safeguard 9.1: Ensure Use of Only Fully Supported Browsers and Email Clients***

Luigi's should allow only fully supported and current web browsers and email clients to execute on devices authorized for company use. Supported applications continue receiving security patches and vendor assistance. This Safeguard reduces the likelihood that employees introduce exploitable client software while accessing corporate networks, email, web services, or sensitive information.

- ***Safeguard 9.2: Use DNS Filtering Services***

Luigi's should use DNS filtering across enterprise network connections to block access to known malicious domains. This Safeguard is important because the PSL malware needed to contact an external command-and-control server before receiving instructions. The filtering should apply even when the requesting device is not centrally managed by Luigi's. Blocking the command-and-control domain could have stopped the attacker before the internal scan and data theft occurred.

- ***Safeguard 9.3: Maintain and Enforce Network-Based URL Filters***

Luigi's should continuously update and enforce reputation-based, category-based, and block-list URL filtering. This Safeguard is important because the company's malicious-destination list was four months out of date. Network-based filtering can also restrict access to unapproved VPN, proxy, file-sharing, and recently created destinations. This protection would have made it more difficult for the attacker to maintain control and transfer information outside the organization.

CIS Control 10: Malware Defenses

- ***Safeguard 10.1: Deploy and Maintain Anti-Malware Software***

Luigi's should require anti-malware protection on every device authorized to access corporate resources. This Safeguard is important because the personal laptop did not contain the company's standard security software. The later boot-time scan found the PSL signature, showing that security software could identify the infection. Requiring anti-malware protection could have detected the malware or caused the laptop to be denied network access.

- ***Safeguard 10.2: Configure Automatic Anti-Malware Signature Updates***

Luigi's should automatically update anti-malware signatures and other detection content. This Safeguard is important because signature-based tools must receive current threat information to identify known malware. Automatic updates reduce dependence on users manually maintaining

protection before connecting their devices. Current signatures would increase the likelihood that PSL was detected when the laptop was inspected or connected.

- ***Safeguard 10.3: Disable Autorun and Autoplay for Removable Media***

Luigi's should disable autorun and autoplay functionality for removable media on all enterprise assets. This Safeguard reduces the possibility that malicious code launches automatically when a USB drive or other removable device is connected. It provides an additional basic defense against malware entering the company environment without deliberate user execution.

- ***Safeguard 10.6: Centrally Manage Anti-Malware Software***

Luigi's should centrally monitor anti-malware protection status, policy compliance, detection versions, malware alerts, and unresolved issues. This Safeguard is important because the company needs visibility into whether connected devices have functioning and current malware protection. A device absent from the management console could be treated as unmanaged and placed into quarantine. Central management would have made the personal laptop's missing protections immediately apparent.

- ***Safeguard 10.7: Use Behavior-Based Anti-Malware Software***

Luigi's should use security software that detects suspicious endpoint behavior in addition to known malware signatures. This Safeguard is important because attackers can modify malware so that it no longer matches an existing signature. Behavior-based protection could identify command-and-control callbacks, internal scanning, unusual compression, and suspicious process activity. These actions could have generated alerts before the PSL malware was positively identified.

CIS Control 11: Data Recovery

- ***Safeguard 11.1: Establish and Maintain a Data Recovery Process***

Luigi's should establish a documented data-recovery process defining recovery scope, priorities, responsible personnel, restoration procedures, and protection requirements for backup data. This Safeguard would not prevent the original theft, but it would support organized recovery if attackers altered, deleted, corrupted, or encrypted company systems and information during the incident.

- ***Safeguard 11.2: Perform Automated Backups***

Luigi's should perform automated backups of critical enterprise assets at least weekly or more frequently based on data sensitivity and operational requirements. Reliable backups would help

restore proprietary files, server configurations, and business information if the incident damaged or destroyed the original systems. Backup completion and failure alerts should be reviewed.

- ***Safeguard 11.3: Protect Recovery Data***

Luigi's should protect recovery data with controls equivalent to those applied to the original information, including encryption, access restrictions, integrity protections, and monitoring. Attackers should not be able to use the same compromised account or network path to modify or delete both production information and the backups needed for recovery.

- ***Safeguard 11.4: Establish and Maintain an Isolated Instance of Recovery Data***

Luigi's should maintain at least one isolated instance of recovery data that is offline, immutable, cloud-isolated, or stored off-site. Isolation would preserve a trustworthy recovery source if an attacker obtained broad access to active servers and connected backup systems. The organization should verify that the isolated copy remains current and recoverable.

CIS Control 12: Network Infrastructure Management

- ***Safeguard 12.1: Ensure Network Infrastructure is Up-to-Date***

Luigi's should keep routers, switches, wireless access points, firewalls, and other network infrastructure on supported and current software versions. Updated infrastructure reduces known vulnerabilities and ensures that segmentation, authentication, traffic filtering, logging, and unauthorized-device detection features remain effective. Software support and versions should be reviewed at least monthly.

- ***Safeguard 12.2: Establish and Maintain a Secure Network Architecture***

Luigi's should design its network around segmentation, least privilege, controlled trust boundaries, resilience, and availability. This Safeguard is important because the network allowed a personal wireless device to access a server containing sensitive information. The environment should be divided into guest, personal-device, employee, server, management, and restricted-data zones. Communication between those zones should be denied unless Luigi's documents and approves a legitimate business requirement.

- ***Safeguard 12.5: Centralize Network Authentication, Authorization, and Auditing***

Luigi's should centrally authenticate and authorize users and devices before granting access to trusted network resources. This Safeguard is important because receiving an IP address should not automatically make an unknown device trusted. Authorization policies could place unrecognized devices into a guest network while audit records identify who connected and when.

This process would have denied or substantially limited the personal laptop's access to internal systems.

- ***Safeguard 12.6: Use Secure Network Management and Communication Protocols***

Luigi's should use secure network technologies such as 802.1X and WPA2-Enterprise or stronger alternatives. This Safeguard is important because enterprise wireless security can require users and devices to authenticate before receiving trusted access. Luigi's could use individual identities, certificates, and centralized authorization to distinguish corporate assets from unknown personal equipment. The infected laptop could then be rejected or assigned only to an isolated guest network.

CIS Control 13: Network Monitoring and Defense

- ***Safeguard 13.1: Centralize Security Event Alerting***

Luigi's should centrally correlate security events from endpoints, servers, logs, network infrastructure, and monitoring tools. This Safeguard is important because the NOC observed individual indicators but did not combine them into a clear security incident. A central platform could correlate a new DHCP client, internal scanning, anonymous FTP activity, and a large, encrypted transfer. The combined alert could have caused the NOC to isolate the device instead of opening a routine support ticket.

- ***Safeguard 13.3: Deploy a Network Intrusion Detection Solution***

Luigi's should monitor network traffic for attack signatures, scanning, command-and-control activity, and other suspicious behavior. This Safeguard is important because intrusion detection can identify malicious patterns without decrypting every transferred file. It may detect unusual FTP activity, internal service scans, known command-and-control indicators, or abnormal communication sequences. These alerts would have provided the NOC with additional evidence that the activity required immediate containment.

- ***Safeguard 13.4: Perform Traffic Filtering Between Network Segments***

Luigi's should restrict communications between wireless, employee, guest, server, management, and sensitive-data network segments. This Safeguard is important because a device on the employee wireless network should not automatically reach a sensitive internal server. Rules could block FTP from wireless and guest networks while allowing approved systems to use a secure replacement service. This filtering would have stopped the compromised laptop from reaching the vulnerable FTP server.

- ***Safeguard 13.6: Collect Network Traffic Flow Logs***

Luigi's should collect network-flow information showing connection sources, destinations, ports, protocols, duration, and transfer volume. This Safeguard is important because flow records remain useful even when the contents of a connection are encrypted. Luigi's could establish alerts for internal scanning and unusually large weekend transfers to new external destinations. This information would support rapid detection, investigation, and containment of the affected device.

CIS Control 14: Security Awareness and Skills Training

- ***Safeguard 14.1: Establish and Maintain a Security Awareness Program***

Luigi's should provide recurring security-awareness training covering personal devices, corporate networks, sensitive information, and suspicious computer behavior. This Safeguard is important because employees need clear rules explaining that personal equipment must not connect without authorization and security verification. The training should also explain the consequences of introducing an infected device into the corporate environment. A recurring awareness program would reduce the likelihood of similar employee actions.

- ***Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks***

Luigi's should train employees to recognize phishing, pretexting, tailgating, fraudulent requests, and other social-engineering techniques. Although this incident began with an infected personal device, stronger recognition skills reduce common methods attackers use to install malware, obtain credentials, or persuade personnel to bypass established security policies and procedures.

- ***Safeguard 14.3: Train Workforce Members on Authentication Best Practices***

Luigi's should train workforce members on multifactor authentication, password composition, credential storage, account sharing, and secure login practices. Employees should understand that strong authentication protects sensitive systems and that anonymous, default, shared, or reused credentials undermine accountability. The training should explain how and where authentication concerns must be reported.

- ***Safeguard 14.4: Train Workforce on Data Handling Best Practices***

Luigi's should train employees to identify, store, transfer, archive, and destroy sensitive information according to its classification. Personnel handling patents, drawings, legal records, pricing data, and parts lists must understand why confidential records cannot be stored on broadly accessible services. Training should also reinforce screen locking and secure workspace practices.

- ***Safeguard 14.5: Train Workforce Members on Causes of Unintentional Data Exposure***

Luigi's should train employees on accidental exposure caused by misconfigured permissions, insecure services, personal devices, lost equipment, improper sharing, and publication to unintended recipients. This training would help personnel recognize that convenience-based decisions can expose confidential information even when an attacker has not defeated properly configured technical controls.

- ***Safeguard 14.6: Train Workforce Members on Recognizing and Reporting Security Incidents***

Luigi's should train employees to recognize suspicious device behavior and report it immediately through an approved process. This Safeguard is important because the employee noticed that the laptop was slow and behaving erratically. The employee did not recognize these symptoms as possible malware indicators and left the device connected throughout the three-day weekend. Faster recognition and reporting would have substantially reduced the amount of time available to the attacker.

- ***Safeguard 14.7: Train Workforce on How to Identify and Report if Their Enterprise Assets are Missing Security Updates***

Luigi's should train employees to identify and report missing operating-system or application updates, disabled antivirus, failed automated patching, and other device-health problems. A personal laptop lacking current protection should have been reported and denied access rather than connected directly to the corporate network. Reporting procedures should identify the responsible IT contact.

- ***Safeguard 14.8: Train Workforce on the Dangers of Connecting to and Transmitting Enterprise Data Over Insecure Networks***

Luigi's should train employees on the risks of connecting to insecure networks and transmitting company information through unapproved connections. Training should cover personal devices, public or home wireless networks, unauthorized VPN services, and the requirement to use approved corporate communication methods. Employees should understand how insecure connections can expose credentials and data.

- ***Safeguard 14.9: Conduct Role-Specific Security Awareness and Skills Training***

Luigi's should provide specialized security training to NOC analysts, help-desk technicians, desktop technicians, administrators, and incident responders. This Safeguard is important because each technical group has different responsibilities during a security incident. NOC analysts should understand that large unexplained encrypted transfers may justify containment, while help-desk personnel should quickly determine device ownership and protection status. Role-specific training would improve technical decisions, evidence handling, and escalation throughout the incident.

CIS Control 15: Service Provider Management

- ***Safeguard 15.1: Establish and Maintain an Inventory of Service Providers***

Luigi's should maintain an inventory of service providers, the services they deliver, their classification, the systems or information they can access, and the internal contact responsible for each relationship. This Safeguard provides basic visibility into third-party dependencies and supports consistent security ownership, review, incident communication, and eventual provider decommissioning.

CIS Control 17: Incident Response Management

- ***Safeguard 17.1: Designate Personnel to Manage Incident Handling***

Luigi's should assign a primary incident coordinator and at least one backup with authority to manage security incidents. This Safeguard is important because the suspicious activity did not receive clear ownership during the holiday weekend. The coordinator could direct containment, investigation, communication, evidence preservation, and documentation. A backup would ensure that response leadership remained available outside normal business hours.

- ***Safeguard 17.2: Establish and Maintain Contact Information for Reporting Security Incidents***

Luigi's should maintain current contact information for employees, incident responders, managers, legal counsel, system owners, service providers, law enforcement, and other parties that may need incident notification. Accurate after-hours contact details would have prevented the response from being delayed until the holiday weekend ended. The contact list should be verified annually.

- ***Safeguard 17.3: Establish and Maintain an Enterprise Process for Reporting Incidents***

Luigi's should document how, when, and to whom employees must report suspected security incidents. This Safeguard is important because both the employee and the NOC needed clear reporting and escalation requirements. The process should identify the reporting timeframe, responsible contact, approved communication method, and minimum required information. Unexplained device behavior and unusually large, encrypted transfers should require immediate reporting rather than delayed ticket submission.

- ***Safeguard 17.4: Establish and Maintain an Incident Response Process***

Luigi's should establish procedures covering incident identification, communication, containment, investigation, evidence preservation, eradication, recovery, and legal obligations. This Safeguard is important because the organization's response consisted of disconnected

actions rather than a coordinated workflow. Responders should have immediately isolated the laptop, blocked the external destination, and restricted access to the FTP server. A formal response process would limit damage and ensure that important investigative and recovery steps were not missed.

- ***Safeguard 17.5: Assign Key Roles and Responsibilities***

Luigi's should assign incident-response responsibilities to information security, IT operations, legal counsel, executives, data owners, human resources, and communications personnel. This Safeguard is important because the stolen information affected several business functions beyond desktop support. The organization should define who approves containment, evaluates notification obligations, contacts affected parties, preserves evidence, and manages recovery. Assigned roles would reduce delays caused by uncertainty over authority and responsibility.

- ***Safeguard 17.6: Define Mechanisms for Communicating During Incident Response***

Luigi's should define primary and backup communication methods for both normal business hours and after-hours incidents. This Safeguard is important because the attack occurred before and during a three-day holiday weekend. The NOC needed reliable methods for reaching security personnel, managers, legal counsel, and system owners outside normal hours. Defined communication channels would have allowed responders to obtain decisions and assistance without waiting until Tuesday.

- ***Safeguard 17.7: Conduct Routine Incident Response Exercises***

Luigi's should periodically test its incident decisions, communication methods, escalation procedures, and response workflows. This Safeguard is important because exercises allow personnel to practice difficult decisions before an actual data breach occurs. Luigi's could test a scenario involving an unmanaged device, encrypted traffic, internal scanning, and intellectual-property theft. Weaknesses involving containment authority, after-hours communication, or team coordination could then be corrected before another incident.

- ***Safeguard 17.8: Conduct Post-Incident Reviews***

Luigi's should review completed incidents, document lessons learned, assign corrective actions, and verify that improvements are completed. This Safeguard is important because confiscating the laptop and closing the support ticket did not address every failure involved in the attack. The review should determine how the device connected, why anonymous FTP existed, why the traffic was not escalated, and which information was exposed. Corrective actions should receive responsible owners, completion deadlines, and evidence showing that the identified weaknesses were resolved.